

硬化梯度：DeFi 安全不平等如何重塑攻击面（2017–2026）

陈世强

中国科学院信息工程研究所

2026年7月

摘要

传统观点认为 DeFi 安全性在不断恶化——每年都带来更大的黑客攻击和破纪录的损失。我们以一个违反直觉的发现挑战这一叙事：在 2017-2026 年间 824 起已确认事件中，**DeFi 风险指数**（年损失/总锁仓量）下降了 30%，从 2020 年的 3.33% 降至 2025 年的 2.33%。然而，这一总体改善掩盖了深刻的结构性分化。我们发现大型协议（\$10 亿+ TVL）的事件数量减少了 75%（2020-2022 vs. 2023-2026），而小型协议（\$100 万 TVL）的事件频率增加了 178%。我们将此分化称为**硬化梯度**：一种安全分叉现象——资源充足的协议日益加固已知攻击向量，而资源不足的协议在基本、可预防的漏洞面前仍然脆弱。该梯度产生三个结构性后果：(1) 攻击面碎片化——攻击者从大型单一目标转向大量小型目标；(2) 中位数损失从 \$1500 万（2020 年）骤降至 \$5 万（2025 年），300 倍的降幅并非由安全性提高驱动，而是由目标迁移驱动；(3) “漏洞底线”——低于约 \$500 万 TVL 的协议进入安全贫困陷阱，仅靠市场力量无法脱困。我们通过新颖的安全弹性模型量化梯度，分解其在审计经济学、漏洞赏金规模、形式化验证可及性和开发者专业知识方面的驱动因素，并提出多管齐下的政策框架——包括集合审计补贴、自动化安全基础设施和基于风险的保险定价——以弥合硬化差距。

1. 引言

1.1 DeFi 安全的悖论

每个季度都带来相同的头条循环：“DeFi 黑客攻击创纪录。”“智能合约利用激增。”“加密损失打破以往纪录。”然而，构成 DeFi 骨干的协议——MakerDAO、Uniswap、Aave V3、Compound、Lido——多年来未发生实质性安全事件，共同管理超过 \$1000 亿的总锁仓量（TVL）。DeFi 如何同时变得越来越危险和越来越安全？

答案在于分布而非总体统计。DeFi 生态系统正在经历结构性分叉：拥有大量资源的协议正实现前所未有的安全硬化，而低于关键资源阈值的协议仍然像生态早期一样脆弱。我们将这种分化称为**硬化梯度**——我们认为，这是当今 DeFi 安全中最重要的结构性趋势。

总体损失数据掩盖了这一梯度。当头条报道“2025 年 DeFi 损失 \$12 亿”时，它们将根本不同的现象合并为单一数字：对两周前上线的 BSC 分叉的 \$80 万闪电贷攻击、对 Solana 借贷协议的 \$500 万访问控制漏洞、以及对 Memecoin AMM 的 \$20 万精度误差利用，全部同等计入总数。硬化的顶层——那些在 2021 年可能是首选目标的协议——几乎不做贡献。总量完全由防御不足、审计不足、资源不足的长尾协议驱动。

1.2 三种错误叙事

在呈现证据之前，我们先回应关于 DeFi 安全的三种流行但错误的叙事：

叙事一："DeFi 越来越糟。" 鉴于每年损失持续上升（2020 年 \$5.76 亿 → 2021 年 \$18 亿 → 2022 年 \$38 亿），这表面上看似合理。但按 TVL 归一化后讲述的是相反的故事：DeFi 风险指数自 2020 年以来下降了 30%。总损失数字上升主要是因为 DeFi 规模扩大，而非其本质上更危险。

叙事二："DeFi 越来越好。" 同样是错误的——或者至少是不完整的。总体改善完全集中在顶层协议。小型协议在这十年间没有显示出有意义的改善，某些指标甚至恶化。

叙事三："闪电贷是主要问题。" 闪电贷攻击自 2021 年峰值下降了 60%，因为预言机硬化（TWAP、Chainlink、偏差区间）已成为标准。但 DeFi 事件总数并未相应下降——攻击者只是转向了抵抗预言机防御的访问控制、授权和协议逻辑向量。

正确的叙事是流行话语完全忽略的：**DeFi 安全正在分化为两个阶层**，二者之间的差距正在扩大。

1.3 贡献

我们做出四项贡献：

1. **硬化梯度概念**——我们引入并形式化了这一观察：DeFi 安全改善是非均匀的，集中在大型协议，并创造了双峰漏洞分布。
2. **实证量化**——使用 824 起事件的 DeFiHackLabs 语料库 [1]，我们在四个 TVL 层级上测量梯度，记录大型协议 75% 的事件减少与小型协议 178% 的增加，以及中位数损失量级 300 倍的骤降。
3. **安全弹性模型**——我们开发了将协议 TVL 与安全投资关联的形式化模型，证明存在“漏洞底线”——低于该底线，市场力量无法提供充分安全。
4. **政策框架**——我们提出具体、可实施的干预措施——集合审计补贴、自动化安全基础设施、渐进式审计定价和基于风险的保险——旨在弥合硬化梯度而不扼杀 DeFi 创新。

2. 方法论

2.1 数据来源

我们使用与伴随论文相同的数据集：

- **DeFiHackLabs**：824 个利用 PoC 合约
- **DeFiLlama**：攻击时刻的 TVL 数据
- **Rekt News**、**SlowMist**、**CertiK Alert**：补充事件叙事

2.2 风险指数计算

$$R(t) = L(t) / TVL(t)$$

其中 $L(t)$ 为年 DeFi 利用损失， $TVL(t)$ 为年平均总锁仓量。

2.3 协议规模分类

层级	TVL 范围	描述
T1	\$1B+	蓝筹协议（Uniswap、Aave、Maker 等）
T2	\$10M-\$1B	成熟中层协议
T3	\$1M-\$10M	早期或利基协议
T4	<\$1M	微型协议、新发行、Memecoin

2.4 时间段划分

- **P1 (2020–2022)**：DeFi 盛夏与跨链桥战争时代
- **P2 (2023–2026)**：成熟化时代（TWAP/Chainlink 广泛采用，形式化验证规模化）

3. 硬化梯度的实证证据

3.1 总体趋势：DeFi 风险指数下降 30%

年份	利用损失	平均 TVL	风险指数
2020	\$576M	\$17.3B	3.33%
2021	\$1.82B	\$81.0B	2.25%
2022	\$3.80B	\$69.7B	5.45%
2023	\$2.00B	\$50.0B	4.00%
2024	\$1.40B	\$50.2B	2.79%
2025	\$1.20B	\$51.5B	2.33%
2026	\$0.40B	\$48.0B	1.67%（年化）

2022 年的峰值（5.45%）代表跨链桥战争异常——Ronin（\$6 亿）、Wormhole（\$3.25 亿）和 Nomad（\$1.52 亿）共同推动指数至历史最高。排除这三起事件，2022 年风险指数为 3.30%，符合长期下行趋势。

3.2 按协议规模的梯度

层级	P1 事件数	P2 事件数	变化	P1 损失	P2 损失
T1 (\$1B+)	12	3	-75.0%	\$1.92B	\$0.38B
T2 (\$10M-\$1B)	28	18	-35.7%	\$2.10B	\$0.65B
T3 (\$1M-\$10M)	45	52	+15.6%	\$0.47B	\$0.38B
T4 (<\$1M)	89	247	+177.5%	\$0.08B	\$0.31B

3.3 中位数损失骤降

年份	中位数损失	受害者 TVL（中位数）
2020	\$15.0M	\$850M
2021	\$5.0M	\$120M
2023	\$0.5M	\$8M
2025	\$0.05M	\$0.8M

中位数损失从 \$1500 万到 \$5 万的 300 倍骤降并非由安全性提高驱动——而是由目标迁移驱动：攻击者从攻击 \$10 亿+ 协议转向攻击 \$100 万协议。

4. 安全弹性模型

4.1 模型设定

协议 i 投资于安全的金额 S_i 与其 TVL 的关系：

$$S_i = \alpha \cdot TVL_i^\beta$$

其中 β 为安全弹性。若 $\beta=1$ ，安全支出与规模线性增长；若 $\beta<1$ ，大型协议在安全上支出比例更低，反之亦然。

4.2 漏洞底线

当协议的 TVL 低于临界阈值 T_c 时，市场力量无法为审计提供充分资金：

$$T_c = C_{audit} / (R_{base} \cdot LGD)$$

其中 C_{audit} 为审计成本（典型 \$30K-\$100K）， R_{base} 为基准剩余风险率， LGD 为违约损失率。
对于典型参数（ $C_{audit}=\$50K$, $R_{base}=2\%$, $LGD=80\%$ ）， $T_c \approx \$3M$ 。低于该阈值的协议面临**安全贫困陷阱**：它们无法负担审计费用，因此无法获得市场信任，因此无法增长 TVL，因此仍然无法负担审计费用。

4.3 四力模型

梯度由四种结构性力量驱动：

1. **审计经济学**：审计价格与协议规模弱相关；\$100 万协议和 \$10 亿协议的审计成本相似
 2. **漏洞赏金规模**：\$10 亿协议的赏金可达 \$1000 万+，有效众包安全；\$100 万协议根本无法竞争白帽注意力
 3. **形式化验证可及性**：Certora、Runtime Verification 需要大量前期投资
 4. **开发者专业知识**：大型协议吸引顶级安全人才；小型协议依赖通用智能合约开发者
-

5. 结构化后果

5.1 攻击面碎片化

攻击者战略已从追求“一生一次”的十亿美元攻击转向追求“日复一日”的五位数攻击。T4 协议中 177.5% 的事件增加并非因为这些协议变得更糟——而是因为 T1 协议已变得极难攻击。

5.2 安全贫困陷阱

一旦协议低于约 \$500 万 TVL：无法负担审计 → 无法获得用户 → 无法增长 → 无法负担审计。DeFi 的自然选择过程原则上有效——不安全的协议不应生存——但在实践中，它破坏了合法创新。下一个 Uniswap 可能永远不会越过安全贫困陷阱。

5.3 跨层攻击路径

硬化协议为攻击者创造了激励，使其寻找连接硬化层和未硬化层的攻击路径。跨链桥攻击（Ronin \$6 亿、Wormhole \$3.25 亿）代表了这一威胁的极端形式——攻击者不直接攻击硬化的 L1 协议，而是攻击连接它们的（未硬化的）桥。

6. 政策干预

集合审计基金：小型协议向共享审计池缴费，池化资源支持批量审计。

自动化安全基础设施：基于符号执行的 CI/CD 管道（Mythril、Slither、Certora）作为公共产品，由协议费用或 Layer 2 排序器收入以 0.1% 税资助。

渐进式审计定价：审计公司对小型协议采用滑动费率，由盈利性大型协议审计的交叉补贴。

基于风险的保险：Nexus Mutual 等保险协议采用 TVL 分层保费——低层协议支付更高费率，激励安全投资。

7. 局限性

1. 数据仅覆盖已报告事件；小型协议中未报告的利用可能被低估
2. 协议可能因非安全原因（产品市场契合度差、治理问题）退出市场
3. 安全弹性模型假设理性经济行为者，可能不适用于所有协议

4. 政策建议未在实践中或模拟中检验
 5. 跨链协议在单一链上的 TVL 可能不能反映其真实安全态势
-

8. 结论

DeFi 安全并非普遍恶化或改善——它正在经历结构性的安全分叉。大型协议（\$10 亿+ TVL）在过去四年中将安全事件减少了 75%，而小型协议（<\$100 万 TVL）增加了 178%。我们将这一现象概念化为**硬化梯度**，并证明它不是暂时的市场波动，而是由审计经济学、安全专业知识的分配和智能合约安全的二元性质驱动的结构特征。

总体指标——无论是上升的总损失还是下降的风险指数——都掩盖了这一梯度。DeFi 安全的话语必须超越“好/坏”的二元叙事，转向承认该领域正在分化为两个世界：一个安全且不断硬化的世界，与一个脆弱且停滞的世界。好消息是存在具体的、可实施的干预措施。坏消息是，没有它们，差距只会扩大。